OWASP A01:2021 – Insecure Direct Object References (IDOR)

IDOR (Horizontal Privilege Escalation Master التصعيد الأفقي للـ Cheatsheet)

دليل مرجعي شامل واحترافي لاكتشاف، تحليل، وتأمين ثغرات الوصول غير المباشر للمعرفات والتحكم بالوصول الأفقي.

1. المفهوم الأساسي والسبب الجذري (Core Concept & Root Cause)

التصعيد الأفقي (Horizontal Escalation / IDOR): قدرة مستخدم (User A) على الوصول إلى بيانات أو إجراء تعديلات على حساب مستخدم آخر بنفس مستوى الصلاحية (User B) عبر التلاعب بـ المعرف المباشر للكائن (Direct Object Identifier).

السبب الجذري (Root Cause): ثقة السيرفر في المعرف المرفق في الطلب (مثل `user_id=102`) دون التحقق في جانب الخادم من ملكية المستخدم المسجل حالياً في الجلسة (`Session Ownership Verification`) لهذا المعرف.

2. أشكال المعرفات وأنواع الكائنات (Identifier Patterns & Categories)

نمط المعرف (Identifier Type)	مثال للبارامتر (Example Parameter)	سلوك الكشف والبحث (Target Pattern)
Sequential Numeric IDs	`id=1001, account_id=554`	أرقام متسلسلة يسهل تخمينها واختبارها فوراً بالتتابع.
Hashed / Encoded IDs	`user=c4ca4238a0b923820dcc509a6f75849b`	تشفير بسيط مثل MD5/Base64 للرقم 1 (سهل التفكيك والتأكد).
Static String Identifiers	`user=john_doe, email=victim@target.com`	معرفات تعتمد على اسم المستخدم أو البريد الإلكتروني المباشر.
UUID / GUID References	`id=a1b2c3d4-e5f6-7890-abcd-1234567890ab`	معرفات عشوائية معقدة (يتطلب البحث عن تسريبها في استجابات أخرى).

3. خطوات الاستطلاع والهجوم المنهجي (Methodology & Attack Steps)

- **الخطوة 1 (حصر المعرفات):** تسجيل الدخول وتصفح جميع الوظائف مع اعتراض الطلبات عبر Burp Suite لحصر البارامترات المسؤولة عن الكائنات (`id,` `account, doc_id, invoice_num`).
- **الخطوة 2 (إنشاء حسابين متماثلين):** تجهيز حسابين في التطبيق (`Attacker Session` و `Victim Session`).
- **الخطوة 3 (مبادلة التوكينات والمعرفات):** إرسال طلب جلب أو تعديل البيانات الخاصة بالضحية باستخدام Cookie أو Header الحساب المهاجم.
- **الخطوة 4 (فحص الاستجابة):** التأكد من نجاح العملية عند استلام استجابة `200 OK` ببيانات الحساب الآخر بدلاً من `403 Forbidden`.

4. تقنيات التجاوز المتقدمة (Advanced Bypass Vectors)

أ. التلاعب بالـ Data Format (Array / JSON):
تحويل المعرف من نص لصفوف مصفوفة مثل `{"id": [101, 102]}` أو `id[]=102` لتجاوز فلاتر الفحص الأحادية.

ب. HPP (HTTP Parameter Pollution):
إرسال بارامتر مكرر: `?user_id=MY_ID&user_id=VICTIM_ID` لاختبار أي المعرفين ينفذه السيرفر خلف الفلتر.

ج. التلاعب بالطرق (HTTP Method Switching):
إذا تم حظر `GET /api/user/102`، تجربة `POST` أو `PUT` أو إضافة الترويسة `X-HTTP-Method-Override: GET`.

د. ثغرات GraphQL & Mass Assignment:
تعديل الـ Object ID داخل الـ GraphQL Mutation أو دمج حقل غير مسموح به مثل `"owner_id": 102` داخل طلب تحديث الحساب.

5. أدوات الأتمتة المتقدمة (Automation Tools & Burp Extensions)

Burp Suite — Autorize:
مقارنة استجابة السيرفر تلقائياً بين Session A و Session B أثناء تصفح المهاجم لتحديد الـ IDOR فوراً.

ParamMiner & AutoRepeater:
اكتشاف البارامترات المخفية تلقائياً وتكرار الطلبات وتعديل المعرفات والترويسات فور صدورها.

6. قواعد البرمجة الآمنة والمعالجة (Secure Code Remediation)

استخدام المعرفات غير المباشرة أو ربط الفحص ببيانات الجلسة الموثوقة من الخادم:

```
@GetMapping("/api/invoice") public Invoice getInvoice(@RequestParam String invoiceId) { // ❌ كود غير آمن (IDOR - الاعتماد التام على المعرف القادم من المستخدم): السيرفر يجلب الفاتورة برقمها مباشرة دون التأكد من ملكيتها للمستخدم الحالي! return invoiceRepository.findById(invoiceId); }
```

✅ كود آمن (سحب المعرف من Session المستخدم المسجل حالياً):

```
@GetMapping("/api/invoice") public Invoice getInvoice(@RequestParam String invoiceId, HttpSession session) { User currentUser = (User) session.getAttribute("currentUser"); Invoice invoice = invoiceRepository.findById(invoiceId); // التحقق الصارم من ملكية الكائن للجلسة الحالية if (invoice == null || !invoice.getOwnerId().equals(currentUser.getId())) { throw new AccessDeniedException("403 Forbidden: Unauthorized Access to Resource"); } return invoice; }
```